

Acme Corporation — IT Asset & Information Security Policy

Hardware Provisioning, IAM, Security Controls, and Acceptable Use

Acme Corporation | Human Resources Department | Effective: January 1, 2026 | Version 4.1

1. Purpose, Scope, and Policy Authority

This Information Technology Asset and Security Policy ('IT Policy') governs the secure acquisition, configuration, acceptable usage, monitoring, and return of all hardware and software assets owned, managed, or licensed by Acme Corporation.

This policy applies universally and without exception to all full-time employees, part-time employees, independent contractors, and third-party vendors who are granted access to any Acme Corp network, system, application, or data — regardless of the access point or geography.

This policy is enacted under the authority of the Chief Information Security Officer (CISO) and is reviewed and updated annually. Policy violations are treated as serious conduct matters and may result in disciplinary action, access termination, or criminal prosecution where applicable law is violated.

2. Asset Provisioning, Account Creation, and IAM

2.1 Identity and Access Management Principles

Acme Corp enforces a strict Principle of Least Privilege (PoLP) across all systems. Employees are granted the minimum level of access required to perform their defined job duties. Access rights are not granted based on seniority or title alone — they must be explicitly tied to a documented business need.

2.2 Automated Base Account Provisioning

Base account creation is automated and directly tied to the Workday HRIS system. IT will not create any accounts manually. Accounts are provisioned in Google Workspace, Slack, and Okta SSO only after HR marks the 'Pre-boarding Checklist' status as 'Complete' in Workday. This integration is the single source of truth.

2.3 Role-Specific Software Access

Access to any software beyond the base set (Google Workspace, Slack, Okta) is not automatic. The hiring manager must submit a formal 'Role-Specific Access Request' ticket in Jira Service Desk with a minimum lead time of 48 hours before the employee's start date. Late submissions will delay access provisioning and will not be expedited as a standard SLA exception.

Required tools by department include, but are not limited to: - Engineering: GitHub Enterprise, AWS Console, Datadog, Sentry, CircleCI - Data Analytics: Tableau, BigQuery, Looker, Databricks - Sales: Salesforce CRM, ZoomInfo, Outreach - Design: Figma, Adobe Creative Cloud, InVision - Finance: NetSuite, Expensify

3. Standard Hardware Configurations and Specifications

Acme Corp standardizes hardware configurations by role to optimize performance, reduce support complexity, and ensure cost efficiency. Deviations from these standards require written approval from the VP of Engineering or VP of Operations.

3.1 Software Engineers

Standard Issue (Mandatory): 16-inch Apple MacBook Pro with M-series processor (M4 Pro or better), 32GB unified memory, 1TB SSD storage. Accompanied by a Logitech MX Keys keyboard, Logitech MX Master 3 mouse, and a Dell 27-inch 4K USB-C monitor.

Justification: Software compilation, running local Docker containers, and machine learning experimentation require high-performance unified memory architecture.

3.2 Data Analysts and Data Scientists

Standard Issue (Mandatory): 14-inch Apple MacBook Pro with M-series processor, 16GB unified memory, 512GB SSD storage. Accompanied by standard peripherals and one 27-inch monitor.

3.3 Business, Operations, and Administrative Staff

Standard Issue: 13-inch Dell XPS 13 (or approved equivalent) with 16GB RAM and 256GB SSD. One 24-inch Dell monitor. Logitech keyboard and mouse.

3.4 Managers and Directors

Standard Issue: Same as the department's technical standard (e.g., an Engineering Manager receives a MacBook Pro equivalent to their Engineers).

3.5 Contractors and Vendors

All independent contractors are strictly subject to a Bring Your Own Device (BYOD) policy. Corporate hardware is not issued to contractors under any circumstances, unless a specific written exemption is obtained from both the VP of Engineering and the CISO.

Contractors using personal devices must install the Acme Corp Endpoint Security Agent (CrowdStrike Falcon) and ensure their device meets minimum OS version requirements before access is granted. Compliance is verified by the IT Security team during onboarding.

4. Mandatory Information Security Controls

All employees are personally responsible for the security of their credentials and devices. These controls are non-negotiable and will be technically enforced where possible.

4.1 Password and Credential Management

All passwords for Acme Corp systems must meet the following minimum requirements: - Minimum length of 14 characters - Must contain at least one uppercase letter, one lowercase letter, one numeral, and one special character - Must not contain the employee's name, username, or common dictionary words - Must be rotated every 90 days - Must be unique per service (password reuse across services is a policy violation)

All employees are required to use the company-provisioned 1Password Teams vault for credential management. Storing passwords in browser extensions, sticky notes, or unencrypted documents is strictly prohibited.

4.2 Multi-Factor Authentication (MFA)

MFA is mandatory and technically enforced on all Acme Corp platforms connected via Okta SSO. The approved MFA method is the Okta Verify application installed on a registered mobile device. SMS-based one-time passwords (OTPs) are explicitly disabled across the entire organization due to known SIM-swapping vulnerabilities. Hardware security keys (FIDO2/WebAuthn) are an approved alternative for senior technical staff.

4.3 Device Security and Encryption

All corporate-issued laptops must have full-disk encryption enabled at all times. For MacOS devices, this means FileVault must be active and managed by Jamf MDM. The encryption key is escrowed by IT. Disabling FileVault is a critical security violation.

The corporate endpoint security agent (CrowdStrike Falcon Sensor) must be installed and active on all corporate and contractor devices. Any attempt to disable or tamper with the endpoint agent will trigger an immediate security incident.

4.4 Network Security

Connecting personal, unauthorized devices to the internal corporate office Wi-Fi network ('AcmeCorp-Internal') is strictly prohibited. A guest Wi-Fi network ('AcmeCorp-Guest') is provided for personal device and visitor use. Unauthorized devices detected on the internal network will be MAC-banned by the network engineering team, and the employee responsible will receive a formal written warning.

When working remotely, employees must connect to the Acme Corp GlobalProtect VPN whenever accessing any internal resource, cloud environment, or data classified as 'Confidential' or above.

5. Software Engineering Security Policies

Engineering staff are granted elevated system privileges, which requires a higher standard of security diligence and awareness.

5.1 Development Environment Setup

Upon receiving their hardware, all Software Engineers must complete the following on Day 1 of employment: 1. Clone the 'acme-bootstrap' repository from GitHub Enterprise (github.acmecorp.internal/bootstrap). This repository contains automated scripts that configure the local development environment, install approved security tooling, and configure Git globals. 2. Run the bootstrap script. This installs pre-commit hooks that prevent secrets, API keys, or credentials from being accidentally committed to any repository.

5.2 GPG Code Signing (Mandatory)

All code commits pushed to any Acme Corp GitHub repository must be cryptographically signed with a valid GPG key. This is technically enforced at the repository level; unsigned commits will be automatically rejected by the CI/CD pipeline.

The GPG key is generated by IT Security during the engineer's Day 1 orientation session and delivered via a secure, encrypted channel. Engineers must not share their private GPG key under any circumstances. Key loss must be reported to IT Security immediately for revocation and reissuance.

5.3 Cloud Resource Access (AWS)

Engineers must access AWS environments via SSO through their Okta account. Direct IAM user accounts with static access keys are strictly prohibited for human users. All AWS access is governed by IAM roles with condition-based policies enforcing MFA and restricting access to specific geographic regions.

5.4 Secret Management

Application secrets, API keys, database connection strings, and cryptographic keys must never be stored in plaintext in code repositories, Slack messages, or unencrypted configuration files. All secrets must be stored in HashiCorp Vault (vault.acmecorp.internal) and retrieved programmatically at runtime.

6. Acceptable Use of Corporate Technology

Corporate technology is provided primarily for business use. Reasonable and limited personal use is permitted, provided it does not interfere with job responsibilities, consume excessive bandwidth, violate the law, or conflict with any part of this policy.

6.1 Prohibited Activities

The following activities are strictly prohibited on any corporate device or network: - Accessing, downloading, or distributing any sexually explicit, threatening, or harassing material - Using company resources for personal commercial activities or for the benefit of a competitor - Installing unapproved third-party software without prior written approval from IT Security - Attempting to circumvent security controls, firewalls, or data loss prevention (DLP) tools - Mining cryptocurrency or using company compute resources for personal projects - Connecting to corporate resources from a sanctioned country as per the CISO's Sanctioned Countries list

6.2 Monitoring and Privacy Notice

Employees should have no expectation of privacy when using Acme Corp's computer systems, networks, or devices. The Company reserves the right to monitor, intercept, access, and review any and all communications, files, and activities transmitted on or stored on company equipment or networks, to the extent permitted by applicable law.

NOTICE: By accepting and using company-provided equipment, you acknowledge and consent to this monitoring policy.

7. Hardware Return, Wipe, and End-of-Life Procedures

7.1 Return upon Offboarding

All corporate hardware must be returned to IT Logistics upon an employee's departure. For office-based employees, assets are returned before the Exit Interview on their last day. For remote employees, the return is managed via pre-paid FedEx (arranged by HR at least 5 business days in advance).

7.2 Secure Data Destruction Protocol

No returned device may be re-issued, repurposed, donated, or disposed of without first undergoing a complete and verified secure data destruction process. IT Logistics technicians must perform a secure wipe conforming to Department of Defense (DoD) 5220.22-M National Industrial Security Program Operating Manual (NISPOM) standards.

Simply reformatting a hard drive or performing a factory reset is explicitly non-compliant and constitutes a critical security policy violation. All wipe events must be logged in the IT Asset Management System (Jamf) with a timestamp, technician ID, and wipe verification certificate.

7.3 Hardware Refresh Cycle

Corporate laptops are replaced on a 3-year refresh cycle. IT will proactively notify employees 60 days before their device reaches end-of-life eligibility. Devices that are damaged, lost, or stolen before the 3-year mark may be replaced at management discretion; theft or loss must be reported to both IT Security and the employee's manager within 4 hours of discovery.